

1. Summary

The search board endpoint has its SQL generated from user input as a string. This lets anybody alter the SQL and find all of the info in the database.

2. Location

The location of it is FILE: src/routes/[items.js](#), searchItems()

3. Concepts

Search term: 'OR '1'='1'

Before the fix: the query becomes OR '1' = '1'

After the fix: the query becomes 0

4. Impact

- Confidentiality: Every user's email and password is disclosed
- Attacks: the homepage is open to anyone

5. Cause

User-controlled values like the category and kind were hardcoded in the SQL as literals instead of parameters, so it accepted improper values. This is why the '?' placeholder is so important.

6. Fix

The fix is to replace any user value with a '?' placeholder

So

```
sql += 'AND items.category = ?';
```

```
sql += 'AND items.kind = ?';
```

7. Verifying

TEST	BEFORE	AFTER
'OR '1'='1	Returned all items	0 results
UNION SELECT	Leaked email and password	0 results
Normal search	1 result	1 result